

Red Team Assessment Report (Adversary Emulation)

Target: acme-shop.example | Engagement: Authorized External Assessment | Date: 2026-06-12 01:30 WIB | TLP:AMBER

OVERALL RISK: HIGH • Confidence: MEDIUM • Mode: Analysis & Planning (no active exploitation)

AUTHORIZATION: Conducted under written authorization, limited to the in-scope assets below, with agreed Rules of Engagement. This report is ANALYSIS & PLANNING only — no exploits were executed. Example / mock data.

1. Engagement Overview

Objective: emulate a realistic external adversary against the client's public web property to identify attack paths and provide prioritized hardening. Used passive OSINT + authorized non-destructive enumeration. Findings are mapped to MITRE ATT&CK and paired with detection & mitigation guidance (purple-team).

2. Scope & Rules of Engagement

Item	Detail
In-scope	acme-shop.example, www., shop. (web app + exposed services)
Out-of-scope	Payment processor, third-party SaaS, social engineering, DoS
Window	2026-06-10 to 2026-06-14 (business hours WIB)
Authorization	Signed RoE; client point-of-contact on standby
Methodology	PTES + OWASP WSTG + MITRE ATT&CK; (Enterprise)

3. Attack Surface

Asset / Service	Exposure	Note
Web app (WordPress)	443/tcp public	CMS + page-builder plugins, versions disclosed
Admin panel /wp-admin	443/tcp public	login reachable, no IP allowlist / no 2FA observed
phpMyAdmin /pma	443/tcp public	DB admin UI exposed to internet
RDP	3389/tcp public	external remote service exposed
Subdomains	public	dev., staging. resolve publicly (non-prod exposed)

4. Attack Paths — MITRE ATT&CK

Attack chain: Recon (T1595) → Initial Access (T1190 / T1133) → Execution (T1059) → Persistence (T1505.003) → Lateral Movement (T1021) → Impact (T1486)

Tactic	ID	Technique	Adversary Opportunity (high-level)
Reconnaissance	T1595	Active Scanning	version/plugin & exposed-service enumeration
Initial Access	T1190	Exploit Public-Facing App	outdated plugin with known RCE (KEV)
Initial Access	T1133	External Remote Services	internet-exposed RDP credential surface
Execution	T1059	Command/Scripting Interpreter	post-access code execution on web host
Persistence	T1505.003	Web Shell	writable web dir enables backdoor
Lateral Movement	T1021	Remote Services	pivot from web host to internal segment
Impact	T1486	Data Encrypted for Impact	ransomware / data theft if unmitigated

5. Findings & Exploitability (sorted by severity)

ID	Finding	Affected	CVSS / EPSS / KEV	Severity
RT-01	Outdated page-builder plugin with known unauth RCE	web app	9.8 / 0.93 / KEV	CRITICAL
RT-03	Internet-exposed RDP (3389)	host	8.1 / — / —	HIGH
RT-02	phpMyAdmin DB console exposed publicly	/pma	7.5 / — / —	HIGH
RT-04	Software / plugin version disclosure	web app	5.3 / — / —	MEDIUM
RT-05	Non-prod (dev/staging) subdomains public	subdomains	4.3 / — / —	LOW
RT-06	Missing security headers (CSP/HSTS)	web app	—	INFO

6. Detection & Hardening (Purple Team)

Finding	Detection Opportunity	Mitigation
RT-01 plugin RCE	WAF exploit-signature alert; new files in web root	Update/remove plugin; WAF virtual-patch; FIM on web root
RT-03 RDP exposed	auth logs: brute-force / impossible-travel	Remove RDP from internet; VPN + MFA; lockout policy
RT-02 phpMyAdmin	access logs to /pma from external IPs	IP allowlist / remove public access; strong auth
RT-04 version disclosure	—	Strip version banners / meta generator; WAF
RT-05 non-prod exposed	DNS monitoring for dev/staging	Restrict to internal/VPN; separate non-prod
RT-06 headers	header scan	Add CSP, HSTS, X-Frame-Options

7. Recommendations (Prioritized)

Priority	Action	Detail
IMMEDIATE	Patch / remove vulnerable plugin	RT-01 — close KEV RCE; deploy WAF virtual patch now
IMMEDIATE	Remove RDP from internet	RT-03 — VPN + MFA; restrict 3389
HIGH	Lock down admin & DB consoles	RT-02 — IP allowlist /pma & /wp-admin; enforce 2FA
MEDIUM	Reduce information disclosure	RT-04 — hide versions; tighten WAF rules
LOW	Segregate non-prod	RT-05 — move dev/staging behind VPN
LOW	Add security headers	RT-06 — CSP/HSTS baseline

8. Appendix — Assets & References

Item	Value
In-scope host	acme-shop.example (authorized)
Exposed services	443 (web), 3389 (RDP), /pma, /wp-admin
Frameworks	MITRE ATT&CK; Enterprise, OWASP WSTG, PTES
Notes	Active exploitation NOT performed; analysis & planning only

TLP:AMBER — Limited disclosure. Engagement under written authorization; analysis & planning only (no exploits executed). Generated 2026-06-12 01:30 WIB by Hermes OSINT Orchestrator. Example / mock data.